

Heutrix legal and privacy operating procedures

Version 2.2 review draft | Prepared 13 September 2026 | Launch date 14 September 2026

These procedures tell the enquiry handler, project lead and authorised approver what to do, which document to use and what evidence to retain. They implement existing boundaries and propose the operating details needed to put them into practice. New roles, response targets and systems still require the approval recorded in document 09. They do not authorise a client contract, real project data, a new system or a marketing campaign.

Keep completed client records in the approved restricted business workspace outside this repository. The files here are blank reusable masters. Record evidence locations and approval references here only when they contain no sensitive information. Janith coordinates decisions and integration; this does not establish signing authority or make him the privacy officer. Shashane is the confirmed website enquiry handler and Rochelle the backup. Assign a project lead, privacy decision-maker, incident lead and Finance approver before their respective work starts.

SOP 01 Opening the launch day

Trigger and responsibility: Before handling enquiries on Monday 14 September, Shashane checks the existing website enquiry journey; Rochelle covers absence. Janith coordinates unresolved decisions.

1. Open the published privacy and terms links in document 07. Confirm they load and show the approved wording dated 12 September. Use the current website repository and PR 16 as release evidence; older website descriptions in the parent repository are historical.
2. Check access to hello@heutrix.com.au and the Formspreet inbox, notification availability, spam folder and submission quota. The recorded 13 September balance is historical; read the current balance. A form receipt is not a booked call.
3. Confirm who is covering enquiries and how the backup is alerted. Agree a call time with the enquirer; do not imply a calendar integration or automatic booking exists.
4. Use only the existing approved website enquiry pathway. Until a pipeline location is approved, do not copy enquiries into a new CRM or spreadsheet. Maintain follow-up in the existing enquiry records and escalate missing tracking capability to Janith.
5. Use the public website notices for enquiries and general resources. Keep every v1 contract, v1 ZIP, obsolete privacy document and legacy Diagnostics operations pack out of the issue workflow. Use the v2.2 review pack only for preparation and review until its release gate closes.
6. Record the check time, checker, backup, policy result, mailbox/provider result and unresolved items in the restricted operating record. A non-functional privacy link or receiving channel is escalated to the website maintainer. Do not claim a failed form was received; use the published email route only if that route is functioning.

Completion evidence: Both policies accessible, mailbox/provider checked, named cover and next actions recorded. Paid-client approval is assessed separately through document 09.

SOP 02 Enquiries referrals and introductory calls

Trigger and responsibility: A new enquiry or referral arrives. Shashane or Rochelle handles it through the approved enquiry pathway.

1. Review only the information needed to route the request. Record business contact details, organisation, high-level workflow problem, permission, owner and next action. Avoid personal, clinical, worker-sensitive or confidential attachments.

2. Acknowledge the request and arrange the 20-minute no-obligation introductory conversation. Explain that the conversation assesses fit and does not approve work or system access. Use the published response wording; any internal service target must be approved before promising it externally.
3. For a referral, check the recorded permission to share the business contact's details. If permission is missing, ask the referrer to arrange a permitted introduction. Do not contact the referred person using unapproved shared details.
4. Ask about the workflow start/end, roles, pain point, tools at a high level, decision-maker and desired outcome. Do not request a completed resource workbook, screen recording, raw spreadsheet, participant record or credentials.
5. Route an uncertain problem to Heutrix Diagnostics, a bounded implementation to Heutrix Workflow Transformation, or AI governance needs to Heutrix AI Guardrails. Direct entry is allowed where fit and prerequisites are clear. Diagnostics is not a compulsory purchase; Guardrails is not an automatic upsell.
6. Use document 04 only when non-public business information must be exchanged and its separate NDA approval gate has closed. An NDA does not authorise paid work, personal data, system access or AI use.
7. Record a fit outcome and dated next action. Do not quote a fee or accept payment until the commercial and contract gates close. If asked to start early, explain that scope and approvals must be finalised first; no informal promise of commencement.

Completion evidence: Safe summary, permission record, fit outcome and next action. If sensitive information arrives unexpectedly, follow SOP 03 immediately.

SOP 03 Unsolicited sensitive information

Trigger and responsibility: Any handler discovers personal, participant, patient, worker-sensitive, credential or confidential material outside its approved route.

1. Stop opening, downloading, forwarding or copying the material. Do not paste it into this repository, an AI tool or a support ticket. If a credential was exposed, ask the responsible administrator to revoke or rotate it through a verified channel; do not repeat the secret.
2. Restrict access where authorised without destroying evidence. Alert the designated privacy/incident contact; until appointed, escalate to Janith for urgent assignment. Do not wait for routine meeting cadence.
3. Record a minimal incident reference, discovery time and timezone, channel, category of information and restricted evidence location. Avoid recording the actual sensitive content in the log title or an email subject.
4. Ask the sender for a general or synthetic description using a separate message that does not quote the material. Explain that the public enquiry route cannot accept these records.
5. The responsible reviewer decides whether lawful collection/retention is justified, whether an incident assessment is required and how removal can be completed across Formspre, notification emails, sent/forwarded copies, attachments, downloads and backups. Preserve records subject to a legal hold or necessary incident investigation; do not promise deletion before it is verified.
6. Record authorised containment, lawful retention exceptions, deletion actions and completion evidence. Continue the fit conversation only with safe information.

Completion evidence: Handling decision and all affected copies accounted for. The mere absence of a copy from the public page does not establish deletion from provider or email records.

SOP 04 Preparing approving and issuing contracts

Trigger and responsibility: A qualified prospect requests a written scope. The nominated project lead prepares it; the verified signatory and commercial approver approve it. The legal reviewer closes document 09's relevant items.

1. Start from the approved master version recorded in the legal review register. Until release is recorded, prepare only a review draft and label it accordingly. Do not send the whole review ZIP as a client contract.
 2. Verify both parties' exact legal names, ABN/ACN where relevant, full notice addresses, monitored notice emails and signing authority. Keep authority evidence in restricted business records. Recheck GST status before quoting or invoicing; the current source records non-registration.
 3. Select document 01 plus document 02 for Diagnostics, or document 01 plus document 03 for Transformation or AI Guardrails. Name the exact CSA version and attach the complete agreement. If there is already a signed CSA, verify it applies and obtain review before substituting terms.
 4. Complete the workflow boundary, deliverables, measurable acceptance criteria, exclusions, dependencies, dates/start condition, review rounds, training, handover and support. For Transformation, preserve the current 30-day in-scope defect position and agree its exact trigger, dates and reporting path. A typical 2-4 week period is conditional, not an unconditional deadline.
 5. Complete private fixed fees, milestones, payment dates, taxes, expenses, cancellation, delay/restart, liability and IP settings under approved rules. No public price, automatic Diagnostics fee credit, unapproved discount or assumed margin exception.
 6. Complete data, tools, tenant, users, locations, subcontractors, insurance and AI selections. Attach form A and any required project notice; attach form B for an approved AI use. A provider brand is not system approval. A client checkbox does not replace Heutrix's approval or applicable legal requirements.
 7. Search the client copy for APPROVE, COMPLETE, **PENDING**, underscores, empty cells, unmatched options and retired service names. Resolve all required fields; mark genuinely inapplicable fields with an explanation. Delete internal review instructions only after approval and never remove substantive conditions silently.
 8. Have a second authorised checker compare the completed scope against approvals, calculations, attachment list and PDF. Record master version, client issue version/date and approval evidence. Store bank details only in approved finance systems; verify any change through an independently known channel.
 9. Send only the approved CSA, selected scope and activated schedules through the approved contract channel. Confirm receipt of all attachments. Obtain both signatures and verify the completed document and signing audit trail. Do not backdate, paste another person's signature or treat an enquiry reply as authority to start.
 10. Record the immutable signed bundle, approved start conditions, payment confirmation and kickoff decision. Do not start paid services, make a production change or grant access until all relevant gates pass.
- Completion evidence: Exact signed bundle, authority, financial approval, project controls and a dated start decision. Any client amendments return to review; silence never closes an approval gap.

SOP 05 Data access and third party approval

Trigger and responsibility: Proposed client information, system access, subcontractor, location or tool change. The project lead prepares form A; authorised client and Heutrix reviewers approve it before access.

1. State the business purpose and test whether synthetic information can achieve it. Check re-identification risk before calling information de-identified; removing names alone is not sufficient.

2. Identify minimum categories and volume, lawful authority, applicable privacy/health-records obligations, required collection notice, prohibited fields and approved audience. A client's permission does not make an otherwise unlawful disclosure lawful.
 3. Identify the exact tenant, application, contract, administrators, data storage and support-access countries, subprocessors, exports and backup locations. Record vendor due diligence, deletion/exit capability and relevant cross-border assessment. Do not assume Australian data residency.
 4. Confirm insurance and signed project controls cover the activity. Obtain written approval for any subcontractor and overseas access before it occurs. No contractor or offshore developer is approved just because a finance model mentions them. A supplier engagement also needs separately reviewed contractor terms, confidentiality, IP, security and access obligations; this client pack is not that agreement.
 5. Grant named, time-limited, least-privilege access with MFA and approved devices. Test access with synthetic data first. Store credentials in the approved credential manager and use a reference in form A, never the secret.
 6. Record access start/expiry, logging, backup/recovery responsibilities, retention class, deletion method, incident contacts and revocation owner. Confirm the granted access matches the signed form before accepting real data.
 7. Recheck approval after a scope, provider, permission, data category or location change. Suspend the affected handling while unresolved; use form C for contractual impacts.
- Completion evidence: Signed form A, vendor/authority checks and permission test. Blank approval fields mean access remains unapproved.

SOP 06 AI use and deployment

Trigger and responsibility: Any AI-assisted client work or material change to an approved AI tool. The project lead prepares form B; named reviewers approve it.

1. Define one use case, tool/model, account, inputs, outputs, audience and accountable human reviewer. Heutrix AI Guardrails is a governance service; purchasing it does not approve every AI tool or provide technical enforcement.
2. Verify provider terms, training/reuse settings, retention, regions, access and appropriate due diligence. Do not put personal/sensitive data into public AI services. A data-class option in the form cannot override a prohibition in the agreement or policy.
3. Check whether suitable client controls already exist. Resolve material gaps before use without assuming a separate Guardrails purchase is necessary.
4. Test synthetic normal and failure scenarios appropriate to the signed scope. Check unsupported output, disclosure, bias, incorrect routing and loss of human oversight. Record evidence and go/no-go authority.
5. Keep clinical, care, safeguarding, eligibility, legal, employment, financial and regulatory decisions with appropriately authorised people. Check output before operational use. Do not claim certification or regulatory assurance.
6. Record approval expiry, review triggers, fallback/disable steps and escalation contacts. A model, provider or data change requires reassessment before the affected use resumes.

Completion evidence: Signed form B, approved tests and human review record. SOP 09 applies to unsafe output or suspected disclosure.

SOP 07 Changes acceptance and defects

Trigger and responsibility: A proposed variation, deliverable review or defect report. The project lead maintains forms C and D; authorised representatives approve material changes and the client decision-maker records acceptance.

1. Compare the request with the signed scope and written acceptance criteria. An in-scope failure under documented conditions is a defect; new features, systems, roles or preference changes are assessed as changes.
2. For a change, complete form C with old/new scope, deliverables, acceptance tests, fees/tax, dates, resources, privacy/access/AI/IP effects and effective date. Obtain signatures before changed work. Emergency protective actions must be limited, recorded and reviewed promptly.
3. Submit the identified deliverable version with test evidence and form D. Set the review deadline from the signed scope. Track criteria individually, correction owners and resubmission dates.
4. Do not infer acceptance from silence under the proposed v2 approach. Remind the client and escalate a missed decision. Use the final legally reviewed signed clause if it differs; never improvise an invoice or acceptance rule.
5. Acceptance with minor items needs written restrictions, owners and dates. A material safety, privacy or security defect blocks affected deployment. Acceptance is separate from operational go-live approval.
6. Preserve non-excludable rights. For Transformation, record the exact start/end of the 30-day qualifying defect period. Do not describe that period as ending statutory rights or providing ongoing enhancements. Retest corrected functions and record closure.

Completion evidence: Signed change if applicable, criterion-level acceptance evidence, authorised operational release and a defect register in the approved project workspace.

SOP 08 Handover retention and closure

Trigger and responsibility: Completion, cancellation, termination or access expiry. The project lead completes form E with the client administrator and authorised approver.

1. Confirm the signed scope and any termination terms. Assemble paid deliverables, editable/source exports and licences as agreed, maps, user guidance, administrator runbook, tests, training evidence and known limitations.
2. Confirm client ownership of accounts, administrators, vendor licences, backup/recovery and ongoing maintenance. Demonstrate the agreed export and recovery path where scoped.
3. Confirm open actions and support dates. Record residual risk acceptance by an authorised person, without treating an unresolved material safety/privacy issue as accepted for use.
4. Revoke named accounts, temporary admin rights, guest links, API tokens, service accounts and other Heutrix access no longer required. Verify removal. Rotate exposed/shared credentials through the client's approved process. Do not retain access merely for possible future work.
5. Apply the signed retention schedule by category. Contracts, finance records, working data, deliverables, logs and backups may have different purposes and rules. Confirm legal holds and statutory obligations with the responsible adviser before deletion. Never impose a blanket 30-day deletion rule on every record.
6. Return or delete each approved working copy through the agreed method. Record provider/email/local copies, backup-cycle expiry, retained record categories, lawful reason, access restrictions and review/deletion dates. Do not mark a backup deleted before its verified expiry.
7. Confirm closure with the client and diarise any outstanding backup deletion or support expiry. Retain the signed form and evidence in the restricted workspace. Client data does not enter Git or a public case study.

Completion evidence: Form E, verified access revocation, data disposition and named owners/dates for remaining lawful exceptions.

SOP 09 Privacy and security incidents

Trigger and responsibility: Suspected loss, unauthorised access/disclosure, malicious activity, exposed credential, unsafe AI output or system compromise. Anyone reports immediately to the designated incident lead; until assigned, escalate to Janith for urgent appointment. Protecting people takes priority.

1. Record discovery time and timezone, reporter, affected systems/categories and restricted evidence location. Contain within authorised access: revoke an exposed token, restrict a link or pause affected processing. Preserve logs and evidence; do not wipe systems or circulate raw records.
2. Escalate promptly to the client contact, responsible privacy/security decision-maker and relevant adviser/insurer through verified channels. Follow the signed notification term and any faster legal deadline. Initial notice can state what is known and what remains under investigation; do not wait for certainty or a complete root-cause report.
3. Assess what happened, recipients, sensitivity, volume, likely harm, whether access continues and whether effective remediation can prevent serious harm. Track facts, assumptions, actions, decisions and next update times.
4. Determine each party's applicable notification obligations. If the federal NDB scheme applies and an eligible breach is suspected, take all reasonable steps to assess within 30 calendar days after awareness of the grounds for suspicion. Treat that as an assessment maximum to work well within, not permission to delay containment or a universal notification deadline. Where notification is required, act as soon as practicable in accordance with the scheme. Consider other applicable laws and contractual/insurer deadlines separately.
5. Coordinate notices to clients, affected individuals and regulators, but do not allow client coordination or approval to prevent a party meeting its own legal duty. Only an authorised person communicates on behalf of another organisation. No admission, reassurance about deletion or statement that no harm occurred without evidence.
6. Restore affected services only after verified remediation and authorised release. Record root cause, control improvements, affected contract/access changes and a lessons review. Close only when outstanding actions and notification decisions are accounted for.

Completion evidence: Restricted incident log, notification assessment and decisions, communications, recovery approval and action owners. Source: OAIC breach assessment and response guidance in document 09.

SOP 10 Privacy requests complaints and deletion requests

Trigger and responsibility: A person contacts hello@heutrix.com.au or another channel about access, correction, deletion or privacy. The enquiry handler acknowledges/routes it; the appointed privacy decision-maker handles the substance.

1. Record date, request type, safe contact reference, requested outcome, owner and review date. Use minimal identity checks proportionate to the request; do not routinely ask for identity documents by ordinary email.
2. Determine whether Heutrix holds the information for its own enquiry purposes or for a client. Locate Formsfree, email and other authorised copies. Refer client-data requests to the client where appropriate, while meeting Heutrix's own obligations; do not simply reject them because a client is involved.
3. Identify applicable law, deadlines, authority and third-party information before releasing, correcting or deleting anything. Apply the published website process; do not invent a fixed public acknowledgment or deletion promise. Set an internal action date and communicate progress if more time is needed.

4. Provide a reasoned response through a verified channel. Explain any lawful refusal, retention requirement, correction annotation or remaining backup copy and available complaint avenues. Do not disclose other people's information.

5. Record the decision, changes across relevant copies, communication and completion evidence. Treat an associated breach concern under SOP 09.

Completion evidence: Verified requester authority, search/assessment, response and closure record, stored outside the repository.

SOP 11 Marketing permissions and website changes

Trigger and responsibility: Proposed promotional message, case study, tracking feature, changed form/vendor or policy update. Marketing and the website maintainer obtain the affected approvals before activation.

1. For commercial electronic messages, establish and retain consent evidence before sending. Do not treat a resource download, public email address or enquiry as blanket marketing consent. Do not send a marketing email merely to ask for consent.
2. Identify the sender and provide accurate contact details and a working unsubscribe. Honour unsubscribe within five working days; keep the mechanism functional for at least 30 days after sending. Maintain the minimum suppression record needed to prevent further marketing.
3. No purchased or harvested list is approved by this pack. Have any uncertain consent basis reviewed before use. This SOP does not authorise messages, social posting, paid advertising or telemarketing.
4. Verify evidence and publication permission separately before using a client name, testimonial or case study. Retain current claim limits. Avoid legal/clinical/compliance assurances and public prices.
5. Before changing forms, analytics, cookies, providers, storage, tracking or retention, map the changed information flow and update the notice if required. Obtain owner/privacy review and test the actual journey before release. Current website approval does not automatically cover a new use.
6. Preserve the previous approved policy version, new approval, effective date and release/rollback evidence. Verify public links and form wording after publication.

Completion evidence: Permission or policy approval, tested unsubscribe/changed journey and versioned release evidence. Source: ACMA guidance in document 09. No marketing messages were sent in preparing this pack.

Rehearsal before real client onboarding

Use synthetic examples only. The proposed operators should walk through: a normal enquiry; a referral without permission; an unsolicited participant attachment; an order with a blank fee/IP setting; an AI request with unapproved data; a scope change; a failed acceptance test; an expired access account; and an incident requiring escalation. Record operator, date, expected action, actual outcome and any fix. A desk review by the preparer does not establish that staff completed the rehearsal.